Стандарт настроек безопасности
СУБД Intersystems Caché

Версия 1.0.1
17.05.2013

Содержание

Введение. 3
Основные настройки безопасности СУБД InterSystems Caché 3
Настройки безопасности ОС 3
Настройки безопасности InterSystems Caché времени установки 4
Настройки безопасности Caché после установки. 4
1 Управление пользователями. 5
2 Протоколирование событий. 10
3 Установка обновлений безопасности. 12

Введение.

Данный стандарт описывает настройки параметров безопасности для СУБД InterSystems Caché 2012.2.3.903.2.

Все системы на базе СУБД InterSystems Caché, к которым предъявляется требования соответствия требованиям PCI DSS, должны быть настроены в соответствии с данным стандартом.

Этот стандарт предполагает, что возможный злоумышленник не имеет физического доступа к ресурсу, так как иначе он может получить к нему полный доступ.

Основные настройки безопасности СУБД InterSystems Caché

Данный стандарт настройки безопасности СУБД InterSystems Caché разработан с учетом требований следующих документов:

1. Caché Security Administration Guide (InterSystems)
2. Caché Installation Guide. Preparing for Caché Security (InterSystems)
3. Caché System Administration Guide (InterSystems)
4. Introduction to Caché. Caché Security (InterSystems)
5. PCI DSS.RU. Требования и процедура аудита безопасности. Версия 2.0
6. InterSystems Caché 5.1 Common Criteria EAL 3 Certification Materials
7. Формуляр сертификата соответствия № 1634 ФСТЭК от 26.06.2008
8. Формуляр сертификата соответствия № 2131 ФСТЭК от 12.07.2010
9. Руководство по администрированию Caché версий 5.2, 2008, 2009, 2010
10. Caché Release Notes (InterSystems)
11. Caché Upgrade Checklists (InterSystems)

Настройки безопасности ОС

Необходимо выполнить следующее:

- Минимизировать права технологической учетной записи СУБД Caché.
- Переименовать учетную запись администратора локального компьютера.
- Оставить в ОС только минимум необходимых пользователей.
- Своевременно устанавливать обновления безопасности для ОС и используемых служб и сервисов.
- Использовать и регулярно обновлять антивирусное программное обеспечение
- Отключить или удалить неиспользуемые службы и сервисы.
- Ограничить доступ к файлам базы данных
- Ограничить права на файлы данных Caché (оставить только у владельца и администраторов БД)
- Для UNIX®/Linux систем требуется создать следующие типы групп и пользователей, которых необходимо создать до начала инсталляции:

    - Owner user ID
    - Management group ID
    - Internal Caché system group ID

- Internal Caché user ID

Настройки безопасности InterSystems Caché времени установки

Производитель СУБД компания Интерсистемс настоятельно рекомендует разворачивать прикладные решения только на версиях не ниже Caché 2012.2.3.903.2.

Дистрибутивные пакеты этих и более поздних версий доступны на сайте Всемирного центра реагирования (WRC) компании Интерсистемс (WRC.InterSystems.com)

При установке необходимо выполнить следующие:
- Выбрать режим установки Locked down (Повышенные)
- Выбрать режим установки Custom Setup и в нем выбрать только те компоненты, которые минимально необходимы для работы прикладного решения
- При установке указать порт SuperServer, отличный от стандартного для установок TCP порта 1972
- При установке указать порт внутреннего веб сервера, отличный от стандартного для установок TCP порта 57772
- В качестве пути для размещения экземпляра Caché указать отличный от стандартного путь (для Windows систем путь по умолчанию C:\InterSystems\Cache, для UNIX®/Linux систем - /usr/Cachesys

Настройки безопасности Caché после установки.

После установки должны быть выполнены следующие действия (большинство из них выполнено при режиме инсталляции Locked down(Повышенные):

- Отключены все сервисы и ресурсы, которые не используются прикладными системами сертифицируемого решения
- Для сервисов, использующих сетевой доступ, должны быть явно заданы IP адреса, с которых возможно удаленное взаимодействие

- Должны быть отключены неиспользуемые CSP веб приложения
- Для необходимых CSP приложений должен быть исключен доступ к ним без аутентификации и авторизации
- Должен быть закрыт паролем и ограничен доступ к CSP Gateway
- Должен быть включен аудит работы СУБД
- Для файла конфигурации должна быть включена опция шифрования

В качестве проверки безопасности настроек системы должен быть запущен с портала управления Security Advisor и выполнены рекомендации по результатам его работы:

- Для сервисов (раздел Services):

  - Ability to set % globals should be turned off — Возможность изменения процентных глобалов должна быть выключена. Так как часто такие глобалы используются для работы системного кода, изменения таких переменных могут привести к непредсказуемым последствиям

  - Unauthenticated should be off — Неаутентифицированный доступ должен быть

выключен. Неаутентифицированный доступ к сервису предоставляет всем пользователям доступ к нему

- Service should be disabled unless required — Если сервис не используется, он должен быть отключен. Доступ к любому сервису, который не используется прикладным решением может обеспечить неоправданный уровень доступа к системе

- Service should use Kerberos authentication — Доступ через любой другой механизм аутентификации не обеспечивает максимальный уровень безопасности

Service should have client IP addresses assigned — IP адреса подключений к сервису должны быть заданы явно. Ограничение IP адресов, с которых соединения будут приняты, позволяют более жестко контролировать соединения к Caché

Service is Public — Public сервисы дают возможность всем пользователям, включая не требующую аутентификации учетную запись UnknownUser, получать нерегулируемый доступ к Caché

Приложения (CSP, Privileged Routine, and Client Applications)

- Application is Public — Public приложения дают возможность всем пользователям, включая не требующую аутентификации учетную запись UnknownUser, получать нерегулируемый доступ к Caché
- Application conditionally grants the %All role — Система не может считаться защищенной, если приложение потенциально имеет возможность делегировать своим пользователям все привелегии
- Application grants the %All role — Приложение явно делегирует все привелегии своим пользователям

1 Управление пользователями.

1.1 Управление системными учетными записями.

Необходимо убедиться, что заблокированы или удалены неиспользуемые системные учетные записи, а для используемых системных учетных записей изменен пароль.
Для определения таких учетных записей необходимо использовать компоненту портала управления Security Advisor. Для этого необходимо зайти в портал управления на **[Home] > [Security Management] > [Security Advisor]** и для записей в разделе Users, для которых Recommendations = "Password should be changed from default password", должна быть произведена смена паролей у соответствующих пользователей.

1.2 Управление привилегированными учетными записями.

Если СУБД администрируют несколько человек, то для каждого должна быть создана персональная учетная запись, наделенная минимально необходимыми привилегиями для выполнения должностных обязанностей.

1.3 Управление правами и привилегиями.

При разграничении доступа необходимо руководствоваться принципом минимальных привилегий. То есть запретить пользователю все, а затем предоставить только права, необходимые для выполнения должностных обязанностей. При назначении привилегий необходимо руководствоваться правилом предоставления привилегий только по ролям. То есть права назначать только для роли, а не для конкретного пользователя, затем присвоить роль конкретному пользователю.

1.4 Разграничение прав доступа.

Для проверки настроек безопасности в плане разграничения прав доступа, запустите Security Advisor. Необходимо выполнить следующие действия в зависимости от рекомендаций, выдаваемых Security Advisor:

• Для ролей (Roles):

- This role holds privileges on the Audit database — Эта роль имеет привилегии доступа к базе аудита. Доступ на чтение позволяет использовать данные аудита ненадлежащим образом. Доступ на запись позволяет скомпроментировать данные аудита

- This role holds the %Admin_Secure privilege — Эта роль включает в себя роль %Admin_Secure, которая позволяет изменять привилегии доступа для других пользователей

- This role holds WRITE privilege on the %CACHÉSYS database — Эта роль дает право на запись в системную базу %CACHÉSYS, что позволяет изменить системный код и системные настройки Caché

• Для пользователей (Users):

- At least 2 and at most 5 users should have the %AII role — По крайней мере, 2 и не более 5 пользователи должны иметь роль %All. Слишком мало пользователей с такой ролью может привести к проблемам доступа в аварийных ситуациях; слишком много пользователей может нарушить общую безопасность системы

- This user holds the %AII role — Этот пользователь имеет роль %All. Необходимо проверить необходимость присвоения этой роли данному пользователю

- UnknownUser account should not have the %AII role — Система не может считаться безопасной, если UnknownUser обладает ролью %All

- Account has never been used — Учетная запись никогда не использовалась. Неиспользуемые учетные записи могут использоваться при попытке получить несанкционированный доступ

- Account appears dormant and should be disabled — Учетная запись неактивна и должна быть отключена. Неактивные учетные записи (те, которые не были использованы в течение 30 дней) могут использоваться при попытке получить несанкционированный доступ

- Password should be changed from default password — Значение по умолчанию для пароля должно быть изменено

При удалении пользователя необходимо убедиться, что роли и привилегии, созданные этим пользователем, удалены, если они не требуются.

1.5 Настройка парольной политики.

Поддержка чувствительности к регистру паролей включена в Caché по умолчанию.

Парольная политика реализуется через портал управления системой в разделе **[Home]>[Security Management] > [System Security Settings] > [System-wide Security Parameters**].

Настройка необходимой сложности паролей происходит с помощью указания шаблона для паролей в параметре Password Pattern. По умолчанию для установки с максимальной

безопасностью Password Pattern = 8.32ANP, что означает использование паролей минимальной длины 8 символов, максимальный размер 32 символа, разрешено использование алфавитно-цифровых символов и символов пунктуации. Для подключения специфичных алгоритмов проверки валидности пароля используется параметр Password validation routine.

Подробное описание приводится в **[1]**, раздел "Password Strength and Password Policies".

Помимо использования внутренних механизмов, аутентификация в Caché может быть делегирована операционной системе, Kerberos или LDAP серверам.

Контролируемый параметр парольной политики	**Требования PCI DSS**	**Настройки в Портале управления системой**
Проверку подлинности пользователя перед сменой пароля.	8.5.2 Изучить парольные процедуры и процедуры аутентификации и убедиться в том, что пользователь проходит проверку подлинности перед сменой пароля по телефону, электронной почте, с использованием веб-приложения или иным удаленным способом.	**[System] > [Security Management] > [Users] >[Edit User] >** Two-factor Authentication Для проверки подлинности можно включить двух-факторную авторизацию с применение SMS по мобильному телефону.
Установка уникального первоначального пароля для каждого пользователя и его немедленное изменение при первом входе пользователя.	8.5.3 Установку уникального первоначального пароля для каждого пользователя и его немедленное изменение при первом входе пользователя.	**[System] > [Security Management] > [Users] >[Edit User] >** Change password on next login
Максимальный срок действия пароля	8.5.9 90 дней	**[System Security]> [System-wide Security Parameters]** Password Expiration Days = 80
Минимальная длина пароля	8.5.10 7 символов	**[System Security]> [System-wide Security Parameters]** Password Pattern = 7.32ANP

Сложность пароля	8.5.11 цифры и символы	**[System Security]> [System-wide Security Parameters]** Password Pattern = 7.32ANP
Запрет повторного использования старых паролей	8.5.12 4 старых пароля	По умолчанию нет. Для реализации можно подключить внешнюю аутентификацию, либо расширить функционал за счет реализации прикладного кода **[System] > [Security Management] > [Users] >[Edit User] >** Password validation routine
Ограничение допустимого числа неправильных попыток ввода, после превышения которых, осуществляется блокировка учетной записи	8.5.13 6 попыток 8.5.14 продолжительность блокировки не менее 30 минут	**[System Security]> [System-wide Security Parameters]** Invalid login limit = 6 Disable account if login limit reached = checked

1.6 Настройка разрыва соединения с базой неактивного соединения

Настройки разрыва соединения с базой для неактивных пользовательских сессий зависят от вида подключения к Caché (PCI DSS 8.5.15).

Для SQL и объектного доступа через TCP параметр задается в разделе портала управления [**Home] > [Configuration] > [SQL Settings] > [General SQL Settings]**, параметр TCP Keep Alive interval (in seconds): установить в значение 900, что будет соответствовать 15 минутам.

Для веб доступа параметр задается в настройке «No Activity Timeout» для [**Home] > [Configuration] > [CSP Gateway Management]**. Значение по умолчанию нужно заменить на 900 секунд, и включить параметр «Применить тайм-аут ко всем подключениям»

2 Протоколирование событий.

2.1 Общие настройки

Чтобы разрешить протоколирование событий аудита необходимо включить данную опцию для всего экземпляра СУБД Caché. Для этого надо зайти в Портал Управления системой на страницу управления Аудитом **([Home] > [Security Management] > [Auditing]**, и убедиться, что опция «Disable Auditing» доступна, а опция «Enable Auditing» - недоступна, что означает, что аудит включен. Обратное означает, что аудит выключен.

Если аудит выключен, то его надо включить, выбрав пункт меню «Enable Auditing».

Просмотр журнала событий возможен через Портал управления системой:

[Home] > [Security Management] > [Auditing] > [View Audit Database]

Также имеются системные классы (утилиты) для просмотра журнала событий. В журнале событий регистрируются, в том числе, следующие данные:

1. Дата и время
2. Тип события
3. Имя учетной записи (user identification)

Доступ к данным аудита управляется ресурсом %DB_CACHEAUDIT Для отключения публичного доступа к данному ресурсу, надо убедиться, что в свойствах данного ресурса для Public закрыты как чтение (Read), так и запись (Write). Доступ к списку ресурсов возможен в портале управления системой **[Home] > [Security Management] > [Resources] > [Edit Resource]**, после чего для выбранного ресурса надо нажать ссылку Edit.

По умолчанию для ресурса %DB_CACHEAUDIT выделена одноименная роль %DB_CACHEAUDIT Чтобы ограничить доступ пользователей к журналам регистрации событий необходимо установить список пользователей, которые входят в данную роль, что может быть сделано и портала управления системой:

[Home] > [Security Management] > [Roles] > [Edit Role] после чего необходимо выбрать кнопку Edit для роли %DB_CACHEAUDIT

2.2 Перечень протоколируемых типов событий

2.2.1 Протоколирование доступа к таблицам, содержащим данные платежных карт (PCI DSS 10.2.1).

Протоколирование доступа к таблицам (наборам данных), содержащих данные платежных карт, осуществляется с помощью следующих механизмов:

1. системного механизма аудита, который делает запись события типа «ResourceChange» в журнал событий при изменении прав доступа к ресурсу, отвечающему за хранение данных платежных карт (доступ для журнала аудита для просмотра вызывается через портал управления системой **[Home] > [Security Management] > [Auditing] > [View Audit Database]**);

2. На прикладном уровне для протоколирования доступа к отдельной записи можно зарегистрировать в системе прикладное событие и вызывать его из прикладной программы при каждом наступлении соответствующего события.

[System] > [Security Management] > [Configure User Audit Events] > [Edit Audit Event]

2.2.2 Протоколирование попыток использования административных привилегий (PCI DSS 10.2.2).

В СУБД Caché протоколируются действия всех пользователей, настройка способа протоколирования выполняется через указание событий, подлежащих протоколированию

[Home] > [Security Management] > [Auditing] > [Configure SystemEvents] Должно быть включено протоколирование всех системных событий.

2.2.3 Протоколирование изменений журнала регистрации событий (PCI DSS 10.2.3).

В СУБД Caché используется единый журнал аудита, который не может быть изменен, за исключением естественного изменения его наполнения и фактов возникновения ошибки, очистки журнала, изменения списка аудируемых событий и т.д., которые вызывают соответствующую запись события AuditChange в журнал.

Задача протоколирования события AuditChange выполнена включением аудита всех событий (см. 2.2.2).

2.2.4 Протоколирование неуспешных попыток получения логического доступа (PCIDSS 10.2.4).

Задача протоколирования неуспешной попытки получения логического доступа выполнена включением аудита всех событий (см. 2.2.2).

По факту попытки получения логического доступа в журнале аудита создается событие «LoginFailure».

2.2.5 Протоколирование попыток получения доступа в систему (PCI DSS 10.2.5).

Задача протоколирования попытки получения доступа в систему выполнена включением аудита всех событий (см. 2.2.2).

По факту неудачной попытки получения доступа в журнале аудита создается событие «LoginFailure». По факту удачной попытки получения доступа в журнале аудита создается событие «Login».

2.2.6 Протоколирование изменения параметров аудита (PCI DSS 10.2.6).

Задача протоколирования изменений параметров аудита выполнена включением аудита всех событий (см. 2.2.2).

По факту попытки получения логического доступа в журнале аудита создается событие «AuditChange».

2.2.7 Протоколирование создания и удаления системных объектов (PCI DSS 10.2.7).

В СУБД Caché протоколируется создание, изменение и удаление следующих системных объектов: ролей, привилегий, ресурсов, пользователей.

Задача протоколирования создания и удаления системных объектов выполнена включением аудита всех событий (см. 2.2.2).

По факту создания, изменения и удаления системных объектов в журнале аудита создаются события «ResourceChange», «RoleChange», «ServiceChange», «UserChange».

2.3 Защита журналов регистрации событий.

Необходимо убедиться, что доступ к ресурсу %DB_CACHEAUDIT ограничен. То есть права на чтение и запись в данный ресурс имеют только администраторы или лица, в чьи обязанности входит мониторинг логов.

3 Установка обновлений безопасности.

Обновления безопасности, закрывающие критичные уязвимости, должны устанавливаться не позднее чем через 30 дней с момента выхода обновления. Необходимую для этого информацию можно получить, например, из источников, рекомендованных поставщиком СУБД Caché:

- http://www.intersystems.com/support/Caché-support.html (раздел Support News за текущий год)
- Через рассылку Caché News (подписка на рассылку производится по ссылке http://www.intersystems.com/support/mailinglist.html)
- Caché News, Alerts, and Advisories http://www.intersystems.com/support/cflash/

После каждого изменения системы рекомендуется использовать Security Advisor.